

Threat Brief: Mitigating Large-Scale Credential Attacks (Updated August 18)

Executive Summary

Identity has effectively become the new perimeter, where cybercriminals are increasingly choosing to log in rather than break in. To accomplish this, attackers frequently gather previously leaked username and password pairs. Gathering these credentials can then allow them to pivot to password spraying against services exposed to the internet, gaining credentials for other products and services.

As this sort of attack occurs frequently, this article will be a resource repository of the following information about these attacks:

- Details of noteworthy large scale credential attacks
- Actionable guidance for mitigating these attacks

TheHatman Attack

- The Hatman attack: In August 2026, the actor TheHatman claimed to have stolen large volume of credentials from organizations' Microsoft Entra tenants

FortiBleed Attack

- Fortibleed Credential Campaign: In June 2026, there was a large-scale password spraying campaign targeting Fortinet devices

Unit 42 recommends auditing remote access logs for suspicious activity with a focus on successful logins shortly after large volume password failure events. We also recommend reviewing and implementing the hardening guidance in this article for edge devices.

Palo Alto Networks customers are better protected from this activity through our products and services, such as:

- [Cortex Cloud Identity Security](#)
- [Unit 42 Deep and Dark Web Service](#)
- [Idira Identity Threat Protection \(ITP\)](#)
- [Idira Multi-Factor Authentication \(MFA\)](#)
- [Idira Privileged Access Management \(PAM\)](#)

The [Unit 42 Incident Response team](#) can also be engaged to help with a compromise or to provide a proactive assessment to lower your risk.

Related Unit 42 Topics	Fortibleed , Credential Theft
-------------------------------	---

Activity From TheHatman

From Aug. 1–Aug. 17, 2026, an actor using the handle "TheHatman" made posts across multiple forums offering to sell employee information for multiple enterprises. TheHatman allegedly exfiltrated from organizations' Microsoft Entra tenants. While TheHatman has claimed this data was stolen using compromised credentials, we have been unable to verify a specific intrusion vector.

This activity was [publicly reported](#) as early as Aug. 16, 2026, and we have offered [initial guidance](#) through social media.

TheHatman claims to have sensitive or confidential information from several high-profile organizations, and this actor has claimed that they used compromised credentials through [MFA fatigue and password spraying](#) attacks to gain unauthorized access to these organizations. Unit 42 has not verified these claims.

FortiBleed Campaign

A large-scale password spraying and credential theft campaign ([“FortiBleed”](#)) against Fortinet devices was initially [disclosed in June 2026](#). We observed attempts targeting MSSQL devices as well, and

have seen reports of Sophos devices also being targeted. While this activity is not targeting Palo Alto Networks devices, we have blocked suspicious login attempts in customer telemetry.

The attackers have used a curated password list to attempt password spraying against services exposed to the internet. We assess that the initial password list for this activity was likely developed through a mix of previous breaches, including the successful exploitation of vulnerabilities. Once the attackers obtain credentials, they add them to their password list for future attempts against additional targets, as well as for logging into accounts they successfully compromised.

The attackers have leveraged a multi-stage process to gain persistent, high-privilege access:

- **Password spraying for initial access:** Massive internet-wide scanning and password spraying attempts against Fortinet, Sophos and MSSQL services
- **Configuration extraction:** Depending on the permissions of their initial access, the actor could exploit a privilege escalation vulnerability prior to pulling device configuration files, including stored credentials
- **Offline Cracking:** Offline password cracking of the stolen credentials adds to the password list used in step one to target new devices, as well as to log into compromised devices to establish persistence as an administrator

We observed an initial access broker (IAB) on the Russian-language cybercrime forum Exploit[.]in claiming responsibility for this campaign, referencing a CVE (no further information), and offering the harvested credentials for sale on June 16, 2026. We have not validated their claims at this time.

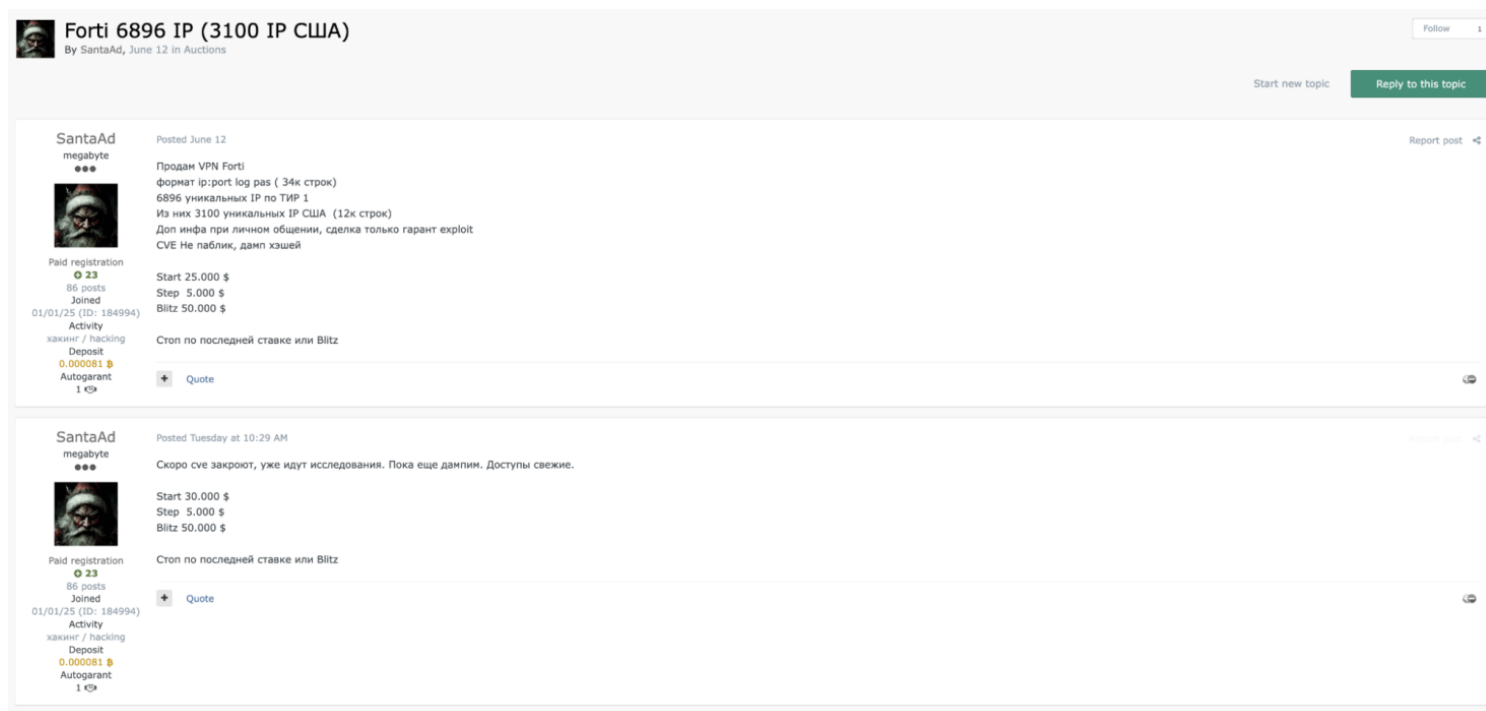


Figure 1. Darkweb post of IAB selling credentials.

[SOCRadar](#) provided the initial reporting on the targeting of FortiGate devices. We observed attempts targeting MSSQL devices as well, and have seen reports of Sophos devices also being targeted.

Interim Guidance

Unit 42 recommends auditing remote access logs for suspicious activity with a focus on successful logins shortly after large volume password failure events. We also recommend reviewing and implementing the hardening guidance below for edge devices.

Palo Alto Networks customers receive assistance protecting against and mitigating credential attacks in the following ways:

- PAN-OS uses a [Master Key](#) to encrypt cryptographic keys in either ES-256-CBC or AES-256-GCM encryption algorithm
- PAN-OS only stores [SHA-256 encrypted and salted hashes](#)
- Customers can [integrate several MFA platforms](#) to enhance their security posture
- Customers can [customize Password Profiles](#) and complexity
- Customers can follow our [Administrative Access Best Practices](#)

Palo Alto Networks also recommends the following hardening guidelines:

- **Require MFA:** Require strong phishing-resistant multi-factor authentication for all remote services. NGFW customers can [integrate several MFA platforms](#) (including Palo Alto Networks Idira MFA) and customize their [Password Profiles](#) and complexity to enhance their security posture.
- **Adopt zero trust architecture:** Leverage “jump boxes” and [Zero Trust Network Access \(ZTNA\)](#) policies to ensure management interfaces are never exposed directly to the public internet, further narrowing the attack surface for configuration extraction.
- **Change default credentials:** Change the credentials for default accounts, ensuring long, complex passwords are used to mitigate the risk of password guessing attempts. Ideally onboard accounts to [Privileged Access Management](#) system and rotate passwords automatically on-time and on-use.
- **Implement ITDR:** Timely detect malicious access attempts and accelerate response with automated identity-centric actions.
- **Disable unused accounts:** Run continuous discovery of privileged accounts. Onboard and disable unused accounts to limit the attack surface.
- **Update and patch:** Ensure you have the latest software versions and patches installed to mitigate known vulnerabilities, including local privilege escalation vulnerabilities.

The [Unit 42 Incident Response team](#) can also be engaged to help with a compromise or to provide a proactive assessment to lower your risk.

Conclusion

We continue to monitor our threat landscape for this and other identity-based attacks. We encourage customers to implement the hunting and hardening recommendations to identify, mitigate, and prevent credential attacks against their networks.

Palo Alto Networks has shared our findings with our fellow Cyber Threat Alliance (CTA) members, including Fortinet. CTA members use this intelligence to rapidly deploy protections to their customers and to systematically disrupt malicious cyber actors. Learn more about the [Cyber Threat Alliance](#).

Palo Alto Networks customers are better protected by our products, as listed below. We will update this threat brief as more relevant information becomes available.

Palo Alto Networks Product Protections For Large-Scale Credential Attacks

Palo Alto Networks customers can leverage a variety of product protections and consulting services to identify and defend against this threat.

If you think you might have been compromised or have an urgent matter, get in touch with the [Unit 42 Incident Response team](#) or call:

- North America: Toll Free: +1 (866) 486-4842 (866.4.UNIT42)
- UK: +44.20.3743.3660
- Europe and Middle East: +31.20.299.3130
- Asia: +65.6983.8730
- Japan: +81.50.1790.0200
- Australia: +61.2.4062.7950
- India: 000 800 050 45107
- South Korea: +82.080.467.8774

Deep and Darkweb Monitoring

Unit 42's [Deep and Dark Web \(DDW\)](#) monitoring is a service that assists clients in identifying sensitive information and leaked credentials that surface on the dark web, providing critical insights to reduce risk exposure and reduce the time between detection and response.

Cortex Cloud

Cortex Cloud [Identity Security](#) encompasses Cloud Infrastructure Entitlement Management (CIEM), Identity Security Posture Management (ISPM), Data Access Governance (DAG) as well as Identity Threat Detection and Response (ITDR) and provides clients with the necessary capabilities to improve their identity related security requirements. By providing visibility into cloud based identities, and their permissions, Cortex Cloud can detect misconfigurations, unwanted access to sensitive data and

real-time analysis surrounding usage and access patterns. Additionally, Cortex Cloud provides protections against credentials that were compromised, lost or exposed being leveraged against cloud resources, such as those discussed within this article.

Idira Identity Threat Protection

[Idira Identity Threat Protection](#) enables security teams to counter identity-based attacks targeting Idira Next Generation Identity (NGI) Platform and the identities it secures. Using near real-time detection, powered by CORA AI, and leveraging Idira's visibility across multiple contexts (like PAM, authentication, SSO, cloud, endpoints, browsers, and more), Idira ITP can apply automated, tailored non-disruptive in-session response to contain and minimize potential identity-based threats.

Idira Multi-Factor Authentication

[Idira Multi-Factor Authentication](#) helps protect organizations against password spraying, credential theft, and other identity-based attacks by verifying that the person signing in is the legitimate user, not just someone with a valid password. Using phishing-resistant MFA, including passkeys, biometrics, and FIDO2 security keys, along with adaptive, risk-based authentication, Idira evaluates signals such as device trust, location, and login behavior. When risk is detected, it requires additional verification before granting access, helping prevent account compromise while keeping access simple for trusted users.

Idira Privileged Access Management

[Idira Privileged Access Management](#) is a SaaS-delivered Privileged Access Management (PAM) solution that mitigates credential compromise and password spraying by prioritizing automated discovery, onboarding, and rotation. The platform continuously scans hybrid environments and infrastructure to detect unmanaged local, domain, service accounts and cloud roles. Discovered credentials are automatically onboarded into a hardened digital vault for centralized management. Privilege Cloud then enforces programmatic transactional credential rotation using complex, randomized strings. This eliminates the static, predictable passwords exploited during spraying attacks,

removing standing privileges and blocking lateral movement across the network infrastructure and devices.

References

- [Analysis of Reported Credential Compromise of Fortigate Devices](#) — Fortinet
- [FortiBleed Breach: How 80,000+ Corporate Firewalls Were Quietly Compromised](#) — SOCRadar
- [What is Zero Trust Network Access \(ZTNA\)?](#) — Palo Alto Networks
- [Next-Generation Firewall: Multi-Factor Authentication](#) — Palo Alto Networks, Tech Docs
- [Administrative Access Best Practices](#) - Palo Alto Networks, Tech Docs
- [Panorama Administrator's Guide: Configure Panorama Password Profiles](#) — Palo Alto Networks, Tech Docs
- [Social media post about TheHatman](#) — LinkedIn, Palo Alto Networks Unit 42
- [What is Zero Trust Network Access \(ZTNA\)?](#) — Palo Alto Networks

Updated June 26, 2026 at 1:00 p.m. PT to add product protection for Idira Security and Cortex Cloud, and more information to the hardening guidelines section.

Updated August 18, 2026 at 1:30 p.m. PT to add information about TheHatman attack.